Политика безопасности

Русская версия ../SECURITY.md (английский оригинал).

Поддерживаемые версии

Поддерживается только ветка `main`: исправления выходят в ней.

Версия	Поддерживается
`main`	✅
старые теги	❌

Как сообщить об уязвимости

Пожалуйста, **не** открывайте публичный issue. Сообщите приватно через private vulnerability reporting (вкладка Security → Report a vulnerability) или напрямую @geff1778.

В сообщении укажите: описание проблемы и её влияние, шаги воспроизведения (по возможности proof of concept), затронутую версию/коммит и предлагаемые меры.

Мы подтверждаем получение в течение 72 часов и после разбора сообщаем сроки исправления. Пожалуйста, дайте разумное время на исправление до публичного раскрытия.

Модель безопасности и меры защиты

BrainStorm — self-hosted приложение; для развёртывания важны следующие решения:

- **Секреты** — у `SECRET_KEY`, `ADMIN_SECRET_KEY` и `CHEAT_TESTER_CODE` **нет** значений по умолчанию. В `ENV=production` приложение не стартует, если они не заданы или короче 16 символов. Храните их в `.env` (вне git) или в секрет-хранилище платформы.
- **Обратный прокси** — `X-Forwarded-For` принимается только при `TRUST_PROXY=true`. Включайте лишь за доверенным прокси, иначе IP клиента (а значит и лимиты) подделываются.
- **Cookie** — `SESSION_COOKIE_SECURE=true` при работе по HTTPS.
- **CORS** — в проде задайте `CORS_ORIGINS` явным списком, а не `*`.
- **Ограничение частоты** — активация привилегированных режимов, аутентификация и AI ограничены в процессе. Для нескольких воркеров нужен Redis (см. ROADMAP.md).
- **Чит/админ-режим** — привилегированные события Socket.IO требуют сессии, активированной через `/api/cheat/activate` или `/api/admin/activate`; коды сравниваются постоянного времени.
- **Хранение паролей** — PBKDF2-HMAC-SHA256 с солью на пароль и 260 000 итераций; старые хеши обновляются при следующем входе.

Если вы нашли пробел в чём-либо из перечисленного — сообщите об этом, как описано выше.